

ISO 27001:2022 KPI Metrics

DOCUMENT CLASSIFICATION	Internal
VERISON	1.0
DATE	
DOCUMENT AUTHOR	Ayaz Sabir
DOCUMENT OWNER	

REVISION HISTORY

VERSION	DATE	REVISION AUTHOR	SUMMARY OF CHANGES

DISTRIBUTION LIST

NAME	SUMMARY OF CHANGE

APPROVAL

NAME	POSITION	SIGN

Contents

1. Introduction.....	4
1.1 Purpose.....	4
1.2 Scope.....	4
1.3 KPI Categories	4
2. Strategic KPIs	5
2.1 ISMS Effectiveness Metrics	5
2.2 Business Impact Metrics.....	6
3. Operational KPI's.....	7
3.1 Incident Management Metrics.....	7
3.2 Vulnerability Management Metrics.....	8
3.3 Access Control Metrics	9
4. Tactical KPI's	10
4.1 Security Control Effectiveness.....	10
4.2 Security Monitoring Metrics	11
5. Compliance KPI's	11
5.1 Audit and Assessment Metrics	11
5.2 Training and Awareness Metrics.....	12
6. Risk Management KPI's.....	13
6.1 Risk Assessments and Treatment	13
7. Third-Party and Supplier KPI's	14
7.1 Supplier Security Management.....	14
8. Business Continuity KPI's	15
8.1 Continuity and Recovery Metrics	15
9. KPI Implementation Guidelines	15
9.1 KPI Selection Criteria	15
9.2 KPI Measurement Process	16
9.3 KPI Dashboard Design	16
10. KPI Reporting Framework.....	16
10.1 Reporting Frequency and Audience	16
10.2 KPI Review and Improvement	17
11. Technology and Tools.....	17
11.1 KPI Measurement Tools	17
11.2 Data Sources.....	17

1. Introduction

1.1 Purpose

This KPI framework is designed to help organizations measure the effectiveness of their ISMS and demonstrate continuous improvement in information security performance. The metrics align with ISO/IEC 27001:2022 requirements for monitoring, measurement, analysis, and evaluation.

1.2 Scope

This framework covers KPIs for all aspects of the ISMS including:

- Security control effectiveness
- Risk management performance
- Incident management efficiency
- Compliance and audit results
- Training and awareness effectiveness
- Business continuity and resilience
- Supplier and third-party security

1.3 KPI Categories

The KPIs are organized into the following categories:

1. **Strategic KPIs** - High-level organizational security performance
2. **Operational KPIs** - Day-to-day security operations effectiveness
3. **Tactical KPIs** - Specific security control and process performance
4. **Compliance KPIs** - Regulatory and standard compliance metrics

2. Strategic KPIs

2.1 ISMS Effectiveness Metrics

<i>KPI Name</i>	<i>Description</i>	<i>Formula</i>	<i>Target</i>	<i>Frequency</i>	<i>Owner</i>
ISMS Maturity Score	Overall maturity assessment of ISMS implementation	$\frac{\text{(Sum of control maturity scores / Total possible score)}}{\times 100}$	$\geq 85\%$	Quarterly	CISO
Security Investment ROI	Return on investment for security initiatives	$\frac{\text{(Security benefits - Security costs)}}{\text{Security costs}} \times 100$	$\geq 15\%$	Annually	CFO/ CISO
Risk Reduction Rate	Percentage reduction in overall risk exposure	$\frac{\text{(Previous risk score - Current risk score)}}{\text{Previous risk score}} \times 100$	$\geq 10\%$ annually	Quarterly	Risk Manager
Security Objective Achievement	Percentage of security objectives met	$\frac{\text{(Objectives achieved / Total objectives)}}{\times 100}$	$\geq 90\%$	Quarterly	CISO
Stakeholder Satisfaction	Satisfaction level of key stakeholders with security posture	Average satisfaction score from surveys	$\geq 4.0/5.0$	Semi-annually	CISO

2.2 Business Impact Metrics

KPI Name	Description	Formula	Target	Frequency	Owner
Security-Related Downtime	Total downtime caused by security incidents	Sum of incident-related downtime hours	< 8 hours /year	Monthly	IT Operations
Business Continuity Test Success Rate	Percentage of successful BCP tests	(Successful tests / Total tests) × 100	≥ 95%	Quarterly	BCP Manager
Customer Trust Index	Customer confidence in organization's security	Customer survey results on security confidence	≥ 4.2/5.0	Semi-annually	Customer Relations
Regulatory Compliance Score	Overall compliance with applicable regulations	(Compliant requirements / Total requirements) × 100	100%	Quarterly	Compliance Officer

3. Operational KPI's

3.1 Incident Management Metrics

KPI Name	Description	Formula	Target	Frequency	Owner
Mean Time to Detect (MTTD)	Average time to detect security incidents	Sum of detection times / Number of incidents	< 4 hours	Monthly	SOC Manager
Mean Time to Respond (MTTR)	Average time to respond to security incidents	Sum of response times / Number of incidents	< 24 hours	Monthly	Incident Manager
Mean Time to Recover (MTTR)	Average time to recover from security incidents	Sum of recovery times / Number of incidents	< 72 hours	Monthly	Incident Manager
Incident Recurrence Rate	Percentage of incidents that recur	(Recurring incidents / Total incidents) × 100	< 5%	Monthly	Incident Manager
False Positive Rate	Percentage of false security alerts	(False positives / Total alerts) × 100	< 15%	Weekly	SOC Manager
Security Incident Trend	Month-over-month change in incident volume	((Current month - Previous month) / Previous month) × 100	Decreasing trend	Monthly	CISO

3.2 Vulnerability Management Metrics

KPI Name	Description	Formula	Target	Frequency	Owner
Critical Vulnerability Remediation Time	Average time to remediate critical vulnerabilities	Sum of remediation times / Number of critical vulnerabilities	< 72 hours	Weekly	IT Security
High Vulnerability Remediation Time	Average time to remediate high vulnerabilities	Sum of remediation times / Number of high vulnerabilities	< 7 days	Weekly	IT Security
Vulnerability Scan Coverage	Percentage of assets scanned for vulnerabilities	$(\text{Scanned assets} / \text{Total assets}) \times 100$	$\geq 95\%$	Weekly	IT Security
Patch Management Compliance	Percentage of systems with current patches	$(\text{Patched systems} / \text{Total systems}) \times 100$	$\geq 95\%$	Weekly	IT Operations
Zero-Day Response Time	Time to implement protection against zero-day threats	Time from threat disclosure to protection implementation	< 24 hours	Per-incident	IT Security

3.3 Access Control Metrics

KPI Name	Description	Formula	Target	Frequency	Owner
Privileged Account Review Compliance	Percentage of privileged accounts reviewed on schedule	$(\text{Reviewed accounts} / \text{Total privileged accounts}) \times 100$	100 %	Monthly	Identity Manager
Access Request Processing Time	Average time to process access requests	$\text{Sum of processing times} / \text{Number of requests}$	< 4 hours	Weekly	Identity Manager
Orphaned Account Detection Rate	Percentage of orphaned accounts identified and removed	$(\text{Removed orphaned accounts} / \text{Total orphaned accounts}) \times 100$	$\geq 95\%$	Monthly	Identity Manager
Multi-Factor Authentication Adoption	Percentage of users using MFA	$(\text{MFA users} / \text{Total users}) \times 100$	$\geq 98\%$	Monthly	IT Security
Password Policy Compliance	Percentage of passwords meeting policy requirements	$(\text{Compliant passwords} / \text{Total passwords}) \times 100$	$\geq 95\%$	Monthly	IT Security

4. Tactical KPI's

4.1 Security Control Effectiveness

KPI Name	Description	Formula	Target	Frequency	Owner
Firewall Rule Effectiveness	Percentage of firewall rules actively used	$\left(\frac{\text{Active rules}}{\text{Total rules}} \right) \times 100$	$\geq 80\%$	Monthly	Network Security
Antimalware Detection Rate	Percentage of malware detected and blocked	$\left(\frac{\text{Detected malware}}{\text{Total malware attempts}} \right) \times 100$	$\geq 99\%$	Weekly	Endpoint Security
Email Security Effectiveness	Percentage of malicious emails blocked	$\left(\frac{\text{Blocked malicious emails}}{\text{Total}} \right)$	$\geq 99.5\%$	Weekly	Email Security
Data Loss Prevention Effectiveness	Percentage of data exfiltration attempts blocked	$\left(\frac{\text{Blocked attempts}}{\text{Total attempts}} \right) \times 100$	$\geq 95\%$	Weekly	DLP Manager
Backup Success Rate	Percentage of successful backup operations	$\left(\frac{\text{Successful backups}}{\text{Total backup attempts}} \right) \times 100$	$\geq 99\%$	Daily	Backup Administrator

4.2 Security Monitoring Metrics

KPI Name	Description	Formula	Target	Frequency	Owner
Log Collection Rate	Percentage of systems sending logs to SIEM	$(\text{Systems sending logs} / \text{Total systems}) \times 100$	$\geq 98\%$	Daily	SOC Manager
Security Event Correlation Rate	Percentage of events successfully correlated	$(\text{Correlated events} / \text{Total events}) \times 100$	$\geq 85\%$	Weekly	SOC Manager
Threat Intelligence Integration	Percentage of threat feeds integrated and active	$(\text{Active feeds} / \text{Total feeds}) \times 100$	$\geq 90\%$	Weekly	Threat Intelligence
Security Dashboard Availability	Uptime of security monitoring dashboards	$(\text{Dashboard uptime} / \text{Total time}) \times 100$	$\geq 99.5\%$	Daily	SOC Manager

5. Compliance KPI's

5.1 Audit and Assessment Metrics

KPI Name	Description	Formula	Target	Frequency	Owner
Internal Audit Findings	Number of findings per internal audit	$\text{Total findings} / \text{Number of audits}$	< 10 per audit	Per audit	Internal Auditor
Audit Finding Closure Rate	Percentage of audit findings closed on time	$(\text{Closed on time} / \text{Total findings}) \times 100$	$\geq 95\%$	Monthly	Compliance Officer

External Audit Success Rate	Percentage of external audits passed without major findings	$(\text{Passed audits} / \text{Total audits}) \times 100$	100%	Per audit	CISO
Control Testing Results	Percentage of controls passing testing	$(\text{Passed controls} / \text{Total controls tested}) \times 100$	$\geq 95\%$	Quarterly	Internal Auditor
Compliance Gap Remediation	Average time to remediate compliance gaps	Sum of remediation times / Number of gaps	< 30 days	Monthly	Compliance Officer

5.2 Training and Awareness Metrics

KPI Name	Description	Formula	Target	Frequency	Owner
Security Training Completion Rate	Percentage of employees completing mandatory training	$(\text{Completed training} / \text{Total employees}) \times 100$	$\geq 98\%$	Quarterly	HR/Training
Security Awareness Test Scores	Average score on security awareness assessments	Sum of scores / Number of participants	$\geq 85\%$	Quarterly	Training Manager
Phishing Simulation Click Rate	Percentage of employees clicking phishing simulation emails	$(\text{Clicks} / \text{Total emails sent}) \times 100$	$< 5\%$	Monthly	IT Security
Security Incident Reporting	Number of security incidents reported by	Count of employee-reported incidents	Increasing trend	Monthly	CISO

Rate	employees				
Training Effectiveness Score	Improvement in security behavior post-training	$(\text{Post-training score} - \text{Pre-training score}) / \text{Pre-training score} \times 100$	$\geq 20\%$ improvement	Quarterly	Training Manager

6. Risk Management KPI's

6.1 Risk Assessments and Treatment

KPI Name	Description	Formula	Target	Frequency	Owner
Risk Assessment Coverage	Percentage of assets covered by risk assessments	$(\text{Assessed assets} / \text{Total assets}) \times 100$	100%	Quarterly	Risk Manager
High Risk Remediation Rate	Percentage of high risks remediated within SLA	$(\text{Remediated high risks} / \text{Total high risks}) \times 100$	$\geq 95\%$	Monthly	Risk Manager
Risk Treatment Plan Completion	Percentage of risk treatment actions completed on time	$(\text{Completed actions} / \text{Total actions}) \times 100$	$\geq 90\%$	Monthly	Risk Manager
Residual Risk Acceptance Rate	Percentage of residual risks formally accepted	$(\text{Accepted risks} / \text{Total residual risks}) \times 100$	$< 10\%$	Quarterly	Risk Manager
Risk Register Currency	Percentage of risk register entries updated within timeframe	$(\text{Updated entries} / \text{Total entries}) \times 100$	$\geq 95\%$	Monthly	Risk Manager

7. Third-Party and Supplier KPI's

7.1 Supplier Security Management

KPI Name	Description	Formula	Target	Frequency	Owner
Supplier Security Assessment Rate	Percentage of suppliers assessed for security	$(\text{Assessed suppliers} / \text{Total suppliers}) \times 100$	100%	Annually	Procurement
Supplier Compliance Rate	Percentage of suppliers meeting security requirements	$(\text{Compliant suppliers} / \text{Total suppliers}) \times 100$	$\geq 95\%$	Quarterly	Procurement
Third-Party Incident Rate	Number of security incidents involving third parties	Count of third- party incidents	< 2 per quarter	Quarterly	Risk Manager
Vendor Risk Score	Average risk score of all vendors	$\text{Sum of vendor risk scores} / \text{Number of vendors}$	< 3.0 (1-5 scale)	Quarterly	Risk Manager

8. Business Continuity KPI's

8.1 Continuity and Recovery Metrics

KPI Name	Description	Formula	Target	Frequency	Owner
Recovery Time Objective (RTO) Achievement	Percentage of systems meeting RTO requirement	$(\text{Systems meeting RTO} / \text{Total critical systems}) \times 100$	100%	Per-test	BCP Manager
Recovery Point Objective (RPO) Achievement	Percentage of systems meeting RPO requirements	$(\text{Systems meeting RPO} / \text{Total critical systems}) \times 100$	100%	Per-test	BCP Manager
Business Continuity Test Success Rate	Percentage of BCP tests meeting success criteria	$(\text{Successful tests} / \text{Total tests}) \times 100$	$\geq 95\%$	Per-test	BCP Manager
Disaster Recovery Drill Frequency	Number of DR drills conducted per year	Count of DR drills	≥ 4 per year	Quarterly	BCP Manager

9. KPI Implementation Guidelines

9.1 KPI Selection Criteria

When selecting KPIs for your organization, consider:

- **Relevance:** Aligns with business objectives and security goals
- **Measurability:** Can be quantified and tracked consistently
- **Actionability:** Provides insights that lead to actionable improvements
- **Timeliness:** Available when needed for decision-making
- **Cost-effectiveness:** Benefits of measurement outweigh costs

9.2 KPI Measurement Process

1. **Define baseline:** Establish current performance levels
2. **Set targets:** Define realistic but challenging targets
3. **Collect data:** Implement automated collection where possible
4. **Analyze trends:** Look for patterns and anomalies
5. **Report results:** Communicate findings to stakeholders
6. **Take action:** Implement improvements based on insights

9.3 KPI Dashboard Design

Effective KPI dashboards should include:

- **Executive summary:** High-level metrics for leadership
- **Operational details:** Detailed metrics for operational teams
- **Trend analysis:** Historical data and trend indicators
- **Alert mechanisms:** Notifications for threshold breaches
- **Drill-down capability:** Ability to investigate underlying data

10. KPI Reporting Framework

10.1 Reporting Frequency and Audience

Report Type	Frequency	Audience	Key Metrics
Executive Dashboard	Weekly	C-Suite, Board	Strategic KPIs, Major incidents, Compliance status
Management Report	Monthly	Department heads	Operational KPIs, Trend analysis, Action items
Operational Report	Daily/Weekly	Security teams	Tactical KPIs, Alerts, Performance metrics
Compliance Report	Quarterly	Auditors, Regulators	Compliance KPIs, Audit results, Remediation status
		All stakeholders	Year-over-year

Annual Review	Annually		trends, Achievements, Strategic planning
---------------	----------	--	--

10.2 KPI Review and Improvement

- **Monthly reviews:** Assess KPI performance and identify issues
- **Quarterly assessments:** Evaluate KPI relevance and effectiveness
- **Annual reviews:** Update to KPI framework based on business changes
- **Continuous improvement:** Refine metrics based on lessons learned

11. Technology and Tools

11.1 KPI Measurement Tools

- **SIEM platforms:** For security event and incident metrics
- **GRC tools:** For compliance and risk management KPIs
- **Business intelligence tools:** For dashboard creation and reporting
- **Automated monitoring:** For real-time metric collection
- **Survey platforms:** For stakeholder satisfaction metrics

11.2 Data Sources

- **Security tools:** Firewalls, IDS/IPS, antimalware, DLP
- **IT systems:** Asset management, patch management, backup systems
- **HR systems:** Training records, employee data
- **Business systems:** Incident management, change management
- **External sources:** Threat intelligence, compliance databases